

MORAA GemVision

Work Audit Log · Phase 4 Operations · generated 2026-10-02

How to use this page: tick the box ☐ at the start of a task once you have checked that it is done and done well. Write the status (done, in progress, blocked, not started) by hand in the empty box at the right of each task, and fill in the summary table below. Nothing on this page is pre-filled with a status. The reasons, decisions (D1, D2...) and errors (E1, E2...) are explained once for the whole phase, after the checklist; tasks refer to them by number.

Domain	Tasks	Done	In progress	Blocked	Not started
1. Visibility	4				
2. Database	1				
3. Logins and administrators	2				
4. Backup and release	3				
Total	10				

Why this phase

Until now nobody could tell whether the live system was healthy: request logs were empty, the health page always said healthy, errors went unseen, there was no backup you could restore, and any logged-in user could use administrator-only endpoints. A shop that takes customers' money needs to find out about a problem before the customer does, recover from a bad day, and control who can do what.

WHAT WAS DONE, IN SHORT

Health pages that really check the database and schema, a metrics page for a dashboard, WhatsApp alerts to the owner for the five things that need a person, error reporting that strips personal data, a request id on every log line, indexes for the slow queries, administrator and token controls on logins, and scripts for backup, restore drill and a safe release.

Checklist

1. Visibility

Know the system's health without reading code.

- ☐ **1.1 /health/ready answers 503 with a reason when the database, schema version or upload folder is wrong**
- FILES backend/app/api/routes/health.py
- HOW TO CHECK Stop the database and open /health/ready from the server: it says not ready and names the database. /health/live still says alive.
- ☐ **1.2 /metrics shows orders by status, daily image use, provider outcomes, pending payments and database state**
- FILES backend/app/services/metrics.py
- HOW TO CHECK Open /metrics from the server after a few orders: moraa_orders and moraa_provider_calls_total have numbers.

-
- ☐ **1.3 The owner gets one WhatsApp message per problem (failure rate, limit nearly used, parked payments, review items, stuck orders)**
- FILES backend/app/services/alert_service.py
- HOW TO CHECK Set OPS_ALERT_WHATSAPP_NUMBERS and create a parked test payment: one message arrives within 5 minutes and not another for an hour. Untested against live WhatsApp.
-

- ☐ **1.4 Every log line of a request and of the background job it starts carries the same short request id; error reports (optional) carry no personal data**
- FILES backend/app/utis/logger.py, backend/app/services/error_tracking.py
- HOW TO CHECK Send a test photo and search the logs for its request id: tap, charge and delivery lines all share it. Sentry itself was not connected.
-

2. Database

-
- ☐ **2.1 Indexes for the slow lookups (migration 0014) and paging for the analyses list**
- FILES backend/alembic/versions/0014_hot_path_indexes.py
- HOW TO CHECK Applied only to test databases. After production is upgraded, /api/analyses answers quickly with 10,000 rows.
-

3. Logins and administrators

-
- ☐ **3.1 Only administrators can use the retry and failure-rate endpoints; a deactivated account stops working at once**
- FILES backend/app/api/dependencies.py, backend/alembic/versions/0015_auth_hardening.py
- HOW TO CHECK Set ADMIN_USERNAMES, call the retry endpoint as an ordinary user: 403.
-
- ☐ **3.2 Refresh tokens are single-use, there is a logout, and reuse revokes the account's older tokens**
- FILES backend/app/services/auth_service.py, backend/app/models/revoked_token.py
- HOW TO CHECK Log in, refresh once (works), refresh again 30 seconds later with the old token (refused and all sessions end).
-

4. Backup and release

-
- ☐ **4.1 A backup script (pg_dump) and a restore drill that proves wallet balances equal their ledgers**
- FILES backend/scripts/db_backup.py, backend/scripts/db_restore_check.py
- HOW TO CHECK Not yet run end to end: this machine has no PostgreSQL client tools. Run both on a machine that has pg_dump and write the date in docs/OPERATIONS_RUNBOOK.md.
-
- ☐ **4.2 A release script upgrades the database and refuses to continue unless the result is right**
- FILES backend/scripts/release.py
- HOW TO CHECK python scripts/release.py --check-only prints what it would do and changes nothing.
-
- ☐ **4.3 Unused and risky settings removed or warned about (for example eager Celery in production)**
- FILES backend/app/config.py
- HOW TO CHECK Start with ENVIRONMENT=production and the default payment link: a warning names the setting.
-

Key decisions and why

D1 Hand-roll a small Prometheus-format metrics page instead of adding a metrics library.

WHY THIS CHOICE

No new dependency to download or audit; the needed numbers are a few counters and gauges.

OTHER OPTIONS CONSIDERED (AND WHY NOT)

- **prometheus-client library** — not chosen because: A new package for a very small need; downloads were avoided.

Relates to task(s): 1.2

D2 Send operations alerts to the owner's WhatsApp, one message per problem with a cooldown stored in the database.

WHY THIS CHOICE

The owner already watches WhatsApp. A database cooldown survives restarts and is shared by every process.

OTHER OPTIONS CONSIDERED (AND WHY NOT)

- **Email only** — not chosen because: Slower to notice; no email service is set up.
- **In-memory cooldown** — not chosen because: A restart would repeat every alert.

Relates to task(s): 1.3

D3 Refresh tokens are single-use; using one twice (outside a short double-tap window) logs the account out everywhere.

WHY THIS CHOICE

A reused token means a copy exists somewhere else; revoking everything makes a stolen token useless.

OTHER OPTIONS CONSIDERED (AND WHY NOT)

- **Reusable refresh tokens until they expire** — not chosen because: A stolen token works for weeks.

Relates to task(s): 3.2

D4 Until an administrator is configured, the admin-only endpoints stay open to any logged-in user (with a log warning).

WHY THIS CHOICE

Turning the check on with nobody configured would lock the owner out of the retry endpoint. Configuring ADMIN_USERNAMES turns it on.

OTHER OPTIONS CONSIDERED (AND WHY NOT)

- **Deny everyone until configured** — not chosen because: Could lock the owner out of a live fix.

Relates to task(s): 3.1

Errors faced

E1 Token issued in the same second as the logout cut-off was refused

Cause: Token timestamps are whole seconds but the cut-off had fractions, so a brand-new token compared as older.

Fix: Compare at whole-second resolution.

Task: 3.2

E2 Reviewer: restore drill script could be pointed at the live database

Cause: Only a Supabase host name was blocked; pg_restore --clean drops tables.

Fix: The target must not equal the application's own database and its name must contain scratch, test or restore.

Task: 4.2

E3 Reviewer: signing up as a different-case copy of an administrator's name could gain admin rights

Cause: ADMIN_USERNAMES was matched case-insensitively but sign-up was case-sensitive.

Fix: Sign-up refuses any name whose lowercase form is an administrator's.

Task: 3.1